



UNIVERSIDAD

## TALLER DE CRIPTOGRAFÍA APLICADA

Caso de Estudio:

# Bitwarden Security Architecture

FDSI | Cryptography | 2026-I

| INFORMACIÓN DEL EQUIPO |                                     |
|------------------------|-------------------------------------|
| Asignatura             | SPTI                                |
| Profesor               | Javier Toquica                      |
| Autores                | Andersson David Sánchez Méndez      |
|                        | Cristian Santiago Pedraza Rodriguez |
| Fecha                  | 2026-18-03                          |
| Ubicación              | Bogotá, Colombia                    |
| Tema                   | Criptografía                        |



## P1 Mecanismos de Criptografía Simétrica

### 1.1 AES-CBC-256 — Cifrado de Bodega (Vault Encryption)

Bitwarden utiliza AES en modo CBC (Cipher Block Chaining) con claves de 256 bits como algoritmo central para cifrar toda la información almacenada en la bóveda. AES-256 es considerado irrompible bajo implementaciones correctas y es adoptado por el gobierno de los EE.UU. para proteger información de alto secreto. La autenticidad del ciphertext se garantiza con HMAC-SHA256.

| AES-CBC-256   Vault Item Encryption |                                                           |
|-------------------------------------|-----------------------------------------------------------|
| Algoritmo                           | Advanced Encryption Standard (AES)                        |
| Modo de operación                   | Cipher Block Chaining (CBC)                               |
| Longitud de clave                   | 256 bits                                                  |
| Autenticación                       | HMAC-SHA256 sobre el ciphertext                           |
| Vector de inicio                    | IV de 128 bits generado por CSPRNG por operación          |
| Que se cifra                        | Cipher Keys de items, Protected Symmetric Key, vault data |
| Donde ocurre                        | Solo en el cliente. El servidor NUNCA ve texto plano.     |

### 1.2 Cipher Keys — Aislamiento criptográfico por ítem

Cada ítem de la bóveda (login, nota, tarjeta, identidad) se cifra con su propia Cipher Key aleatoria de 64 bytes. Esa Cipher Key se cifra con la User Symmetric Key (o la Organization Symmetric Key) antes de enviarse al servidor. Esto garantiza que comprometer una clave no expone todos los ítems.

|                                                                                                      |                                                                                                   |
|------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| <b>Capa 1 — Dato del ítem</b><br>Cifrado con Cipher Key propia<br><i>(AES-256-CBC + HMAC-SHA256)</i> | <b>Capa 2 — Cipher Key del ítem</b><br>Cifrada con User/Org Symmetric Key<br><i>(AES-256-CBC)</i> |
|------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|

### 1.3 PBKDF2-SHA256 / Argon2id — Derivación de clave del Master Password

Para convertir el master password en una clave criptográfica segura, Bitwarden usa funciones de derivación de clave (KDF). Por defecto se aplica PBKDF2 con SHA-256. El usuario puede migrar a Argon2id para mayor resistencia a ataques de GPU.

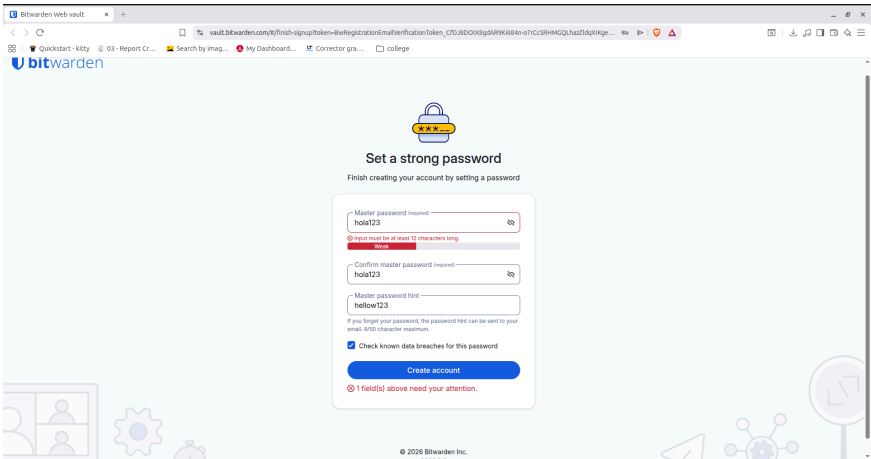
| KDF   Key Derivation Function |                                               |
|-------------------------------|-----------------------------------------------|
| Algoritmo (default)           | PBKDF2-SHA256                                 |
| Alternativa                   | Argon2id (configurable por el usuario)        |
| Iteraciones cliente           | 600,000 rounds (configurable)                 |
| Iteraciones servidor          | 600,000 rounds adicionales con salt aleatorio |
| Salt (cliente)                | Email del usuario (lowercase)                 |
| Salida                        | Master Key de 256 bits                        |

|                   |                                                     |
|-------------------|-----------------------------------------------------|
| Segunda expansión | HKDF -> Stretched Master Key de 512 bits            |
| Propósito         | Derivar claves fuertes desde un password arbitrario |

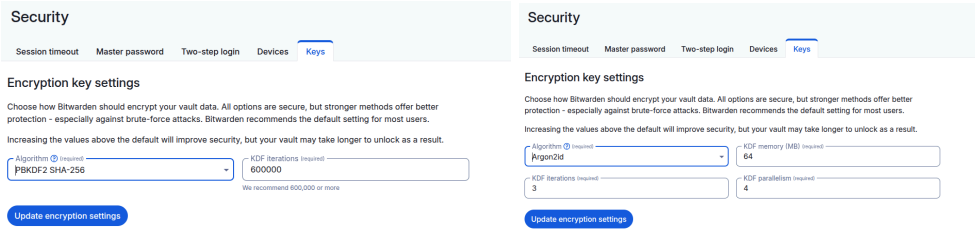
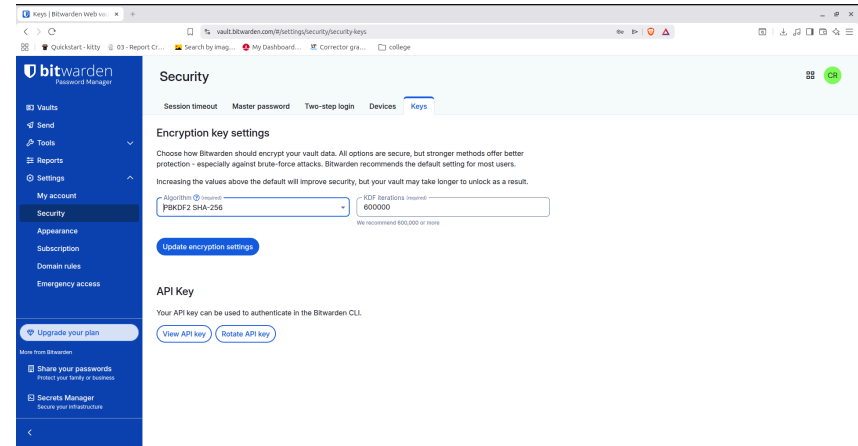
1.4 HKDF — Expansion a Stretched Master Key

La Master Key de 256 bits se expande a 512 bits con HMAC-based Extract-and-Expand KDF (HKDF). Esta Stretched Master Key descifra la Protected Symmetric Key. Ni la Master Key ni la Stretched Master Key son transmitidas al servidor ni almacenadas localmente.

**NOTA** Todo el cifrado simétrico ocurre localmente en el dispositivo. Los servidores de Bitwarden sólo almacenan ciphertext. El servidor nunca tiene acceso a ninguna clave en texto plano.



Medidor de fortaleza del Master Password



Configuración de KDF — PBKDF2 vs Argon2id

P2 Mecanismos de Criptografía Asimétrica

2.1 RSA-OAEP — Par de claves por usuario

Al crear una cuenta, Bitwarden genera un par de claves RSA por usuario. Este par es fundamental para compartir datos (organizaciones) y para operaciones como acceso de emergencia. La clave privada RSA se almacena cifrada con la User Symmetric Key; solo el propietario autenticado puede acceder a ella.

| RSA-OAEP   Asymmetric Key Operations |                                                          |
|--------------------------------------|----------------------------------------------------------|
| Algoritmo                            | RSA con padding OAEP                                     |
| Generación                           | Al momento de crear la cuenta (vía CSPRNG)               |
| Clave privada RSA                    | Almacenada cifrada con User Symmetric Key en el servidor |
| Clave pública RSA                    | Almacenada en claro en el servidor                       |
| Uso principal                        | Cifrar/descifrar Organization Symmetric Key al compartir |
| También usado en                     | Emergency Access, Account Recovery, SSO Trusted Devices  |

2.2 Flujo de compartición en organizaciones (Zero-Knowledge)

Cuando se crea una organización, se genera una Organization Symmetric Key (AES). Esta clave simétrica se cifra RSA con la clave pública del creador. Nunca se almacena en texto plano en los servidores.

|   |                                                                                                         |
|---|---------------------------------------------------------------------------------------------------------|
| 1 | Se genera la Organization Symmetric Key mediante CSPRNG.                                                |
| 2 | Org Symmetric Key se cifra con RSA Public Key del creador -> Protected Org Symmetric Key -> servidor.   |
| 3 | Al iniciar sesión, el cliente descifra Protected Org Symmetric Key con su RSA Private Key.              |
| 4 | Al agregar un miembro: el admin re-cifra la Org Symmetric Key con la RSA Public Key del nuevo usuario.  |
| 5 | Cada miembro tiene su propia Protected Org Symmetric Key; todas descifran a la misma Org Symmetric Key. |

2.3 RSA en Emergency Access

La User Symmetric Key del usuario otorgante (grantor) se cifra con la RSA Public Key del contacto de emergencia (grantee). En emergencia, el grantee descifra con su RSA Private Key y accede a la bóveda. Bitwarden no tiene acceso en ningún momento.

| Emergency Access   Key Exchange |                                     |
|---------------------------------|-------------------------------------|
| Clave compartida                | User Symmetric Key del grantor      |
| Protegida con                   | RSA Public Key del grantee          |
| Descifrada con                  | RSA Private Key del grantee (local) |

|                          |                                                  |
|--------------------------|--------------------------------------------------|
| <b>Tipos de acceso</b>   | View-only   Takeover (con nueva master password) |
| <b>Periodo de espera</b> | Configurable por el grantor (horas/días)         |

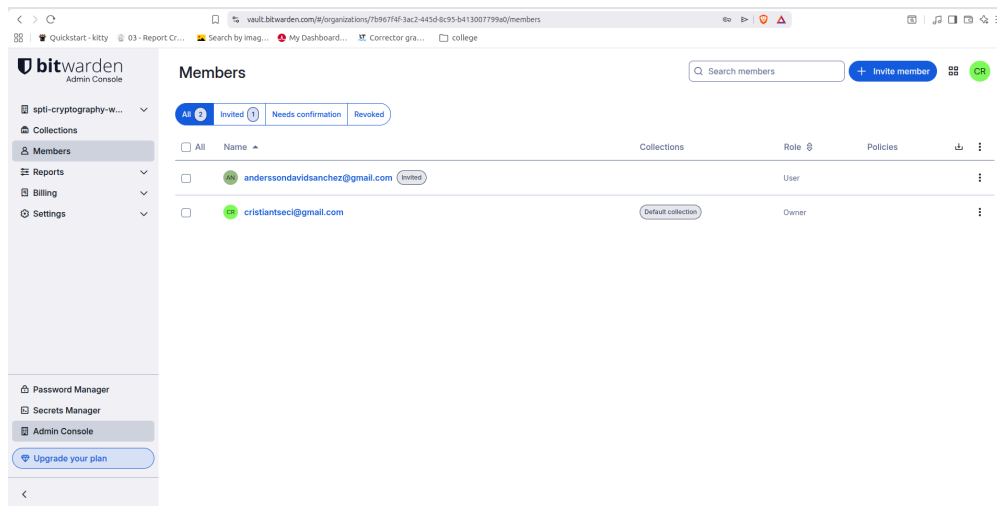
## 2.4 WebAuthn / FIDO2 — Passkeys (ES256 / ECDSA)

Bitwarden soporta passkeys para autenticación y descifrado de boveda via la extensión PRF del estándar WebAuthn. Las passkeys usan criptografía de clave pública basada en ES256 (ECDSA con curva P-256).

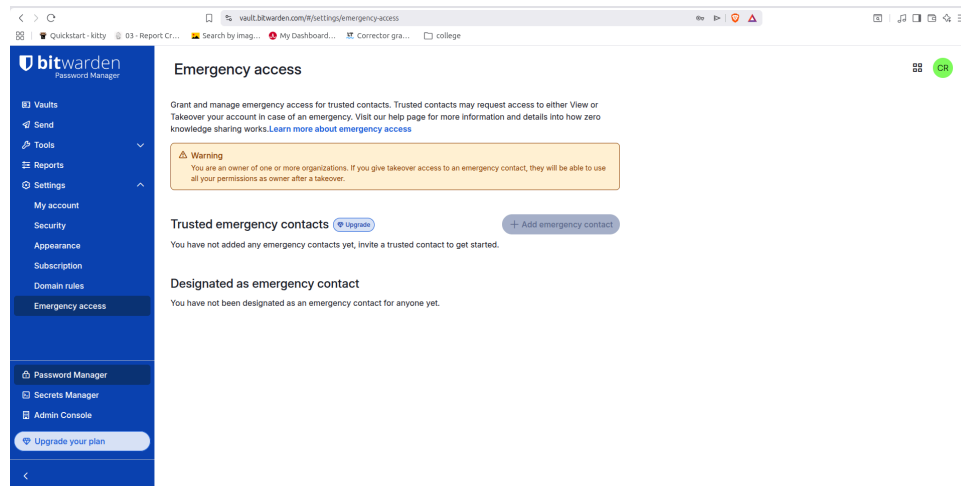
| FIDO2 / WebAuthn Passkeys |                                                                 |
|---------------------------|-----------------------------------------------------------------|
| <b>Algoritmo de firma</b> | ES256 (ECDSA con curva P-256)                                   |
| <b>Extension WebAuthn</b> | PRF (Pseudo-Random Function) para derivación de clave simétrica |
| <b>PRF Symmetric Key</b>  | Derivada del secreto interno de la passkey + salt de Bitwarden  |
| <b>Que protege</b>        | User Symmetric Key (account encryption key)                     |
| <b>Ventaja principal</b>  | Reemplaza completamente el master password                      |
| <b>Almacenamiento</b>     | Passkey Private Key nunca sale del cliente sin cifrar           |

## 2.5 RSA en SSO con Trusted Devices

Al marcar un dispositivo como 'de confianza' se genera un par RSA específico del dispositivo (Device Public/Private Key). La User Symmetric Key se cifra con la Device Public Key. Al autenticar desde ese dispositivo, se descifra con la Device Private Key (que a su vez se descifra con una Device Key que nunca sale del cliente).



### Gestión de miembros en Organización



## Emergency Access — Configuración de contacto de emergencia

### P3 ¿Por qué el Master Password no puede ser recuperado?

#### 3.1 Arquitectura Zero-Knowledge

La imposibilidad de recuperar el master password no es una deficiencia: es la consecuencia directa del diseño Zero-Knowledge de Bitwarden. El equipo de Bitwarden nunca puede ver el master password de ningún usuario. Esta es la garantía de privacidad fundamental del producto.

##### CONCEPTO

*Zero-Knowledge significa que el proveedor del servicio NO tiene acceso matemáticamente posible a los datos del usuario, incluso si lo quisiera.*

#### 3.2 Qué ocurre con el master password — flujo completo

- 1 Usuario ingresa su master password en el cliente (dispositivo local).
- 2 PBKDF2-SHA256 (600,000 iteraciones, salt=email) -> Master Key de 256 bits.
- 3 HKDF expande la Master Key -> Stretched Master Key de 512 bits. Esta descifra la bóveda.
- 4 Master Password Hash = PBKDF2(Master Key, salt=master password). Este hash se envía al servidor para autenticación.
- 5 En el servidor el hash se re-hashea con PBKDF2 + salt aleatorio antes de almacenarse.
- 6 El master password original NUNCA sale del dispositivo. El servidor solo recibe el hash del hash.
- 7 Tras usarlo, el master password es eliminado de memoria por el cliente.

### 3.3 Razones técnicas de la irrecuperabilidad

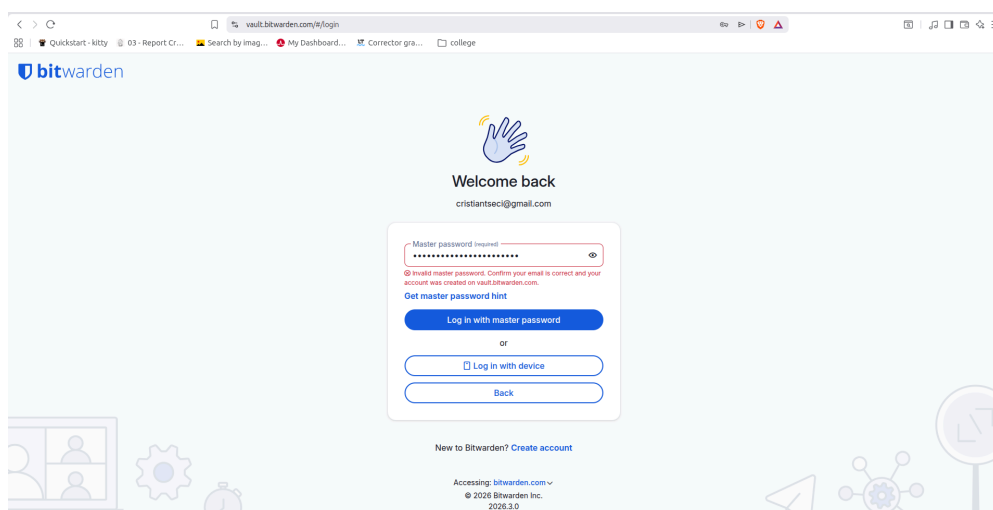
| Razón                                    | Explicación técnica                                                                                                               |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| <b>Función de hash unidireccional</b>    | PBKDF2/SHA-256 son funciones de sentido único: dado el hash, es computacionalmente inviable obtener el input original.            |
| <b>Nunca se transmite al servidor</b>    | El master password en texto plano nunca viaja por la red. Solo se transmite el hash.                                              |
| <b>No se almacena localmente</b>         | El cliente purga el master password de memoria inmediatamente después de derivar la Master Key.                                   |
| <b>Datos cifrados con clave derivada</b> | Incluso con acceso al servidor, solo se obtiene ciphertext. Sin master password, los datos son ilegibles.                         |
| <b>Salt único por usuario</b>            | Salt = email del usuario -> el mismo master password genera hashes distintos para distintos usuarios, invalidando rainbow tables. |
| <b>600,000+ iteraciones en KDF</b>       | El costo computacional hace que ataques de fuerza bruta sean prácticamente inviables en tiempo útil.                              |

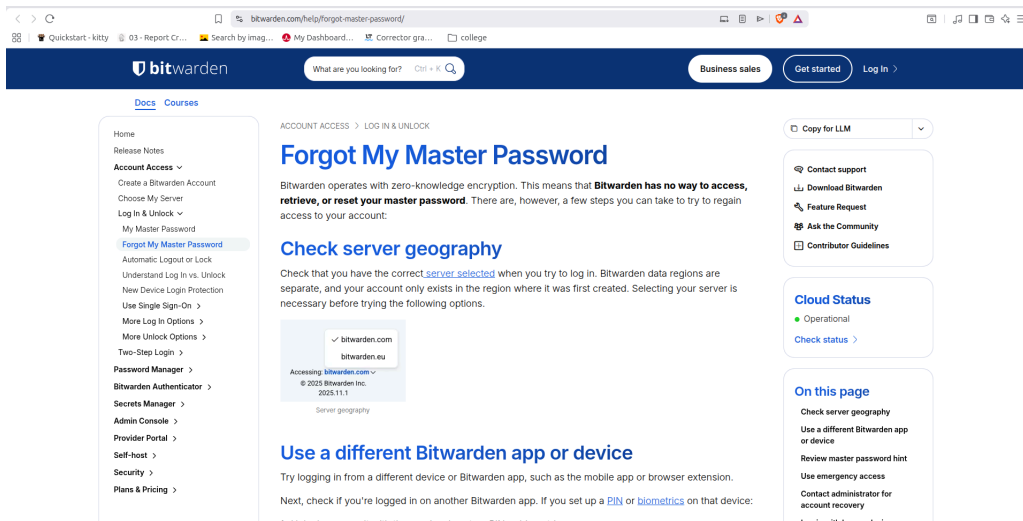
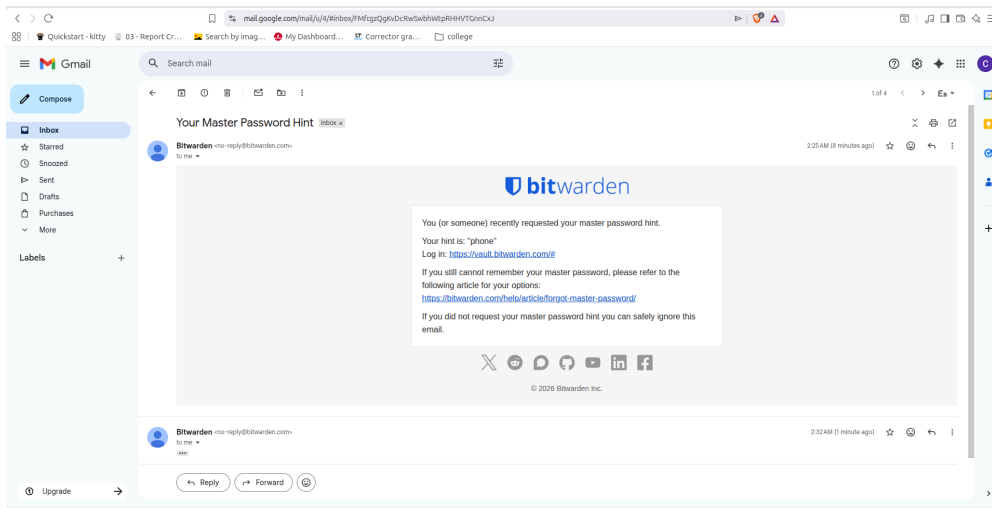
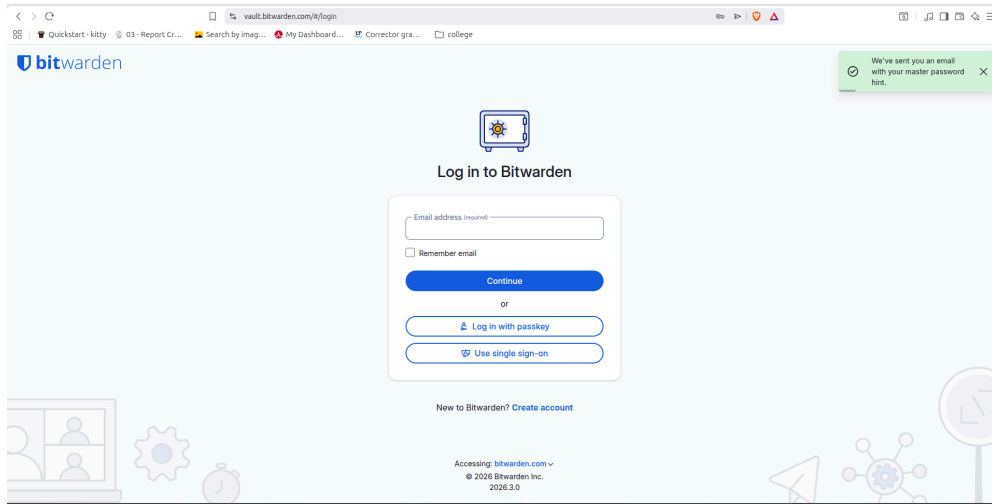
#### CONSECUENCIA

*Si el usuario olvida su master password y no tiene Emergency Access o Account Recovery activos (Enterprise), perderá acceso a su bóveda de forma PERMANENTE. Esta es una garantía de seguridad, no un bug.*

### 3.4 Alternativas para mitigar el riesgo

- ▶ Emergency Access: contacto de confianza puede solicitar acceso tras periodo de espera definido por el usuario, usando RSA.
- ▶ Account Recovery (Enterprise): administradores cifran la User Symmetric Key del miembro con la RSA Public Key de la organización.
- ▶ Recovery Code: código de un solo uso para desactivar 2FA si se pierde el dispositivo secundario. Bitwarden NO puede desactivar 2FA por soporte.





## 'Forgot master password' — Flujo Zero-Knowledge - Hint



P4 Mecanismos de Protección del Acceso al Baul

4.1 Master Password con medidor de fortaleza e HIBP

El primer mecanismo de protección es el master password. Bitwarden incluye un medidor de fortaleza en tiempo real y advierte si el password es débil. Además integra la API de Have I Been Pwned (HIBP) para verificar si el master password aparece en filtraciones conocidas.

4.2 Two-Step Login (2FA) — Métodos disponibles

Bitwarden soporta múltiples factores de autenticación. Incluso conociendo el master password, sin el segundo factor no es posible acceder a la bóveda.

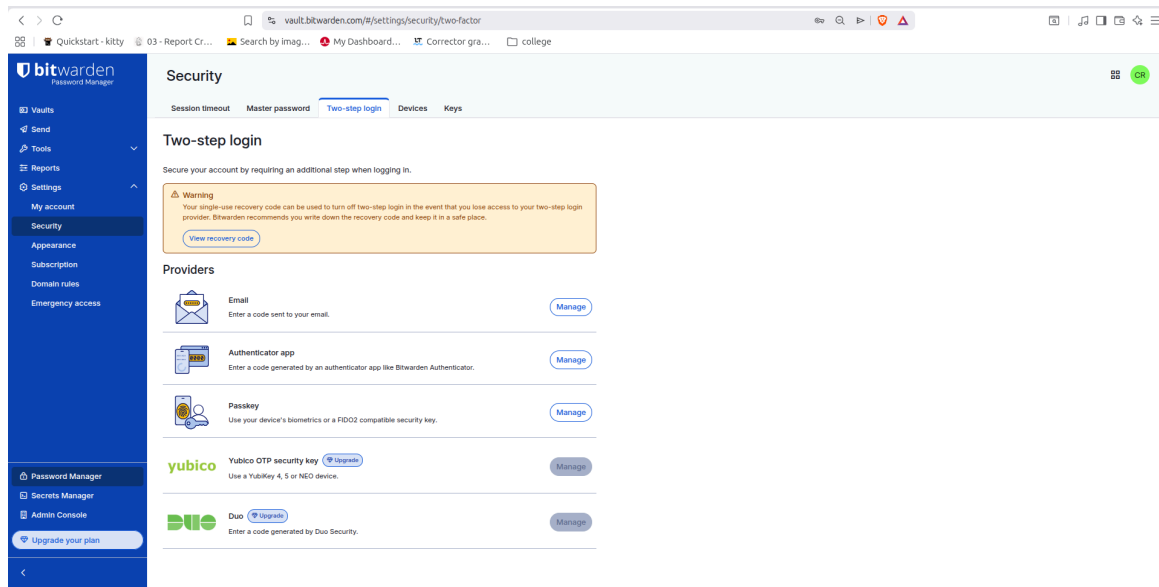
| Método 2FA        | Descripción                                                            | Nivel    |
|-------------------|------------------------------------------------------------------------|----------|
| FIDO2 WebAuthn    | Llaves de seguridad físicas (YubiKey, Google Titan). Máxima seguridad. | Premium  |
| Authenticator App | TOTP con Authy, Google Authenticator, Aegis (30 seg, 6 dígitos).       | Gratuito |
| Email OTP         | Código de un solo uso enviado al correo registrado.                    | Gratuito |
| Duo Security      | Integración empresarial con push notification, SMS, llamada.           | Premium  |
| YubiKey OTP       | Compatible con YubiKeys via OTP legacy.                                | Premium  |

4.3 Métodos alternativos de autenticación

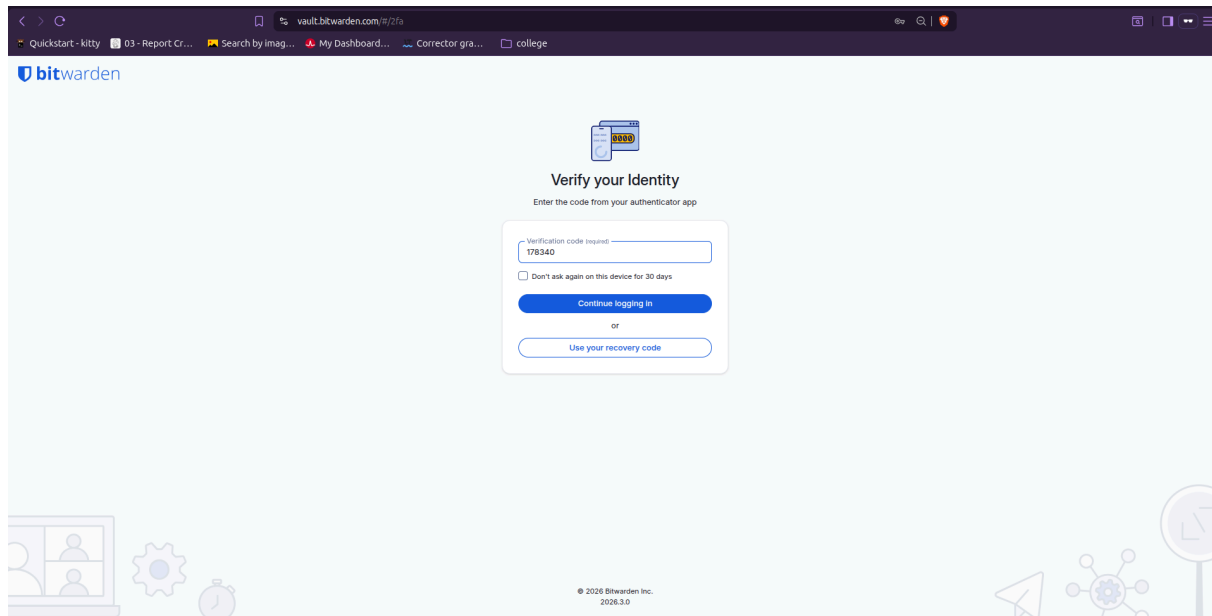
- Log in with device: auth-request con clave pública única por sesión. Aprobación desde dispositivo ya autenticado cifra la User Key. Elimina la necesidad del master password en el dispositivo nuevo.
- Log in with passkeys (FIDO2/WebAuthn): la passkey reemplaza el master password completamente. Usa criptografía ES256. La Passkey Private Key nunca sale del cliente sin cifrar.
- SSO con Trusted Devices: autenticación via SSO corporativo + descifrado de bóveda con Device Key almacenada en el dispositivo de confianza, sin ingresar master password.

4.4 Controles adicionales de acceso

- Vault Timeout: la bóveda se bloquea automáticamente tras inactividad configurable. Al bloquear, claves de cifrado y datos de bóveda son purgados agresivamente de memoria.
- Vault Lock vs Logout: al bloquear (no cerrar sesión), la User Symmetric Key permanece en memoria cifrada para desbloqueo rápido. Al cerrar la sesión completamente, todo se purga.
- Recovery Code de 2FA: código de un solo uso para desactivar 2FA si se pierde el dispositivo. Bitwarden no puede desactivar 2FA por soporte bajo ninguna circunstancia.
- Vault Health Reports: reportes de passwords reutilizados, débiles o expuestos en brechas. Se ejecutan localmente; Bitwarden nunca ve los datos descifrados.



## Configuración de Two-Step Login — Vista general de metodos



### Authenticator app ✓

Enter a code generated by an authenticator app like Bitwarden Authenticator.

Manage

## Pantalla de código TOTP (2FA activo)

## P5 Mecanismo de Protección de Datos en Reposo

### 5.1 Cifrado end-to-end antes de salir del cliente

El mecanismo más fundamental de protección en reposo es que todos los datos se cifran localmente antes de salir del dispositivo. Los servidores de Bitwarden sólo almacenan ciphertext. Es técnicamente imposible obtener datos legibles de los servidores, incluso con acceso físico a ellos.

### 5.2 Capas de protección en reposo

| # | Capa                                       | Descripción                                                                                                    |
|---|--------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| 1 | <b>Cifrado por ítem (cliente)</b>          | Cada vault item cifrado con Cipher Key propia (AES-256-CBC). El Servidor nunca ve texto plano.                 |
| 2 | <b>Cifrado de Symmetric Keys (cliente)</b> | User Symmetric Key protege las Cipher Keys. Derivada del master password, nunca almacenada en servidor.        |
| 3 | <b>Azure Transparent Data Encryption</b>   | TDE de Azure cifra la base de datos completa, backups y logs de transacciones. Claves gestionadas por Azure.   |
| 4 | <b>Column-level encryption (servidor)</b>  | Columnas sensibles (hashes, protected user keys) cifradas con un KMS de acceso estrictamente controlado.       |
| 5 | <b>HTTPS / TLS 1.2+ (en tránsito)</b>      | TLS con certificados X.509 para toda comunicación cliente-servidor. HSTS fuerza el uso de TLS.                 |
| 6 | <b>HTTP Security Headers</b>               | HSTS, Content Security Policy (CSP), X-Frame-Options: SAMEORIGIN contra XSS, clickjacking y downgrade attacks. |

### 5.3 Azure Transparent Data Encryption (TDE)

La base de datos de Bitwarden en Azure esta protegida por TDE. Esta tecnología cifra en tiempo real la base de datos completa, archivos de backup y logs de transacciones cuando no están en uso. Las claves de TDE son gestionadas por Azure, y solo los componentes autorizados del servidor Bitwarden pueden acceder a ellas. Es un nivel de protección de infraestructura adicional e independiente al cifrado end-to-end del cliente.

### 5.4 Key Management Service (KMS) para columnas sensibles

Para el cifrado a nivel de columna de datos especialmente sensibles (como hashes de master password y protected user keys), Bitwarden utiliza un KMS de acceso estrictamente controlado con roles y auditoría. Las claves del KMS son distintas de las claves de cifrado de usuario.

## 5.5 Flujo completo de un dato desde creación hasta reposo

|   |                                                                                                  |
|---|--------------------------------------------------------------------------------------------------|
| 1 | Usuario crea o modifica un ítem en su bóveda.                                                    |
| 2 | El cliente genera una Cipher Key aleatoria de 64 bytes específica para ese ítem.                 |
| 3 | El dato del ítem se cifra con la Cipher Key usando AES-256-CBC + HMAC-SHA256.                    |
| 4 | La Cipher Key se cifra con la User Symmetric Key (o Org Symmetric Key si es compartido).         |
| 5 | El ciphertext resultante se envía al servidor de Bitwarden vía HTTPS/TLS.                        |
| 6 | En Azure, TDE cifra la base de datos completa en reposo automáticamente.                         |
| 7 | Columnas adicionales sensibles reciben cifrado extra mediante el KMS de Bitwarden.               |
| 8 | El dato sólo es descifrable por el usuario autenticado con su master password en su dispositivo. |

### CONCLUSIÓN

*La protección en reposo de Bitwarden es multicapa: (1) cifrado AES-256 en el cliente antes de transmitir, (2) TDE de Azure en la infraestructura, (3) cifrado adicional de columnas sensibles con KMS. Incluso con acceso completo a los servidores, un atacante sólo obtendría ciphertext inutilizable.*

## Referencias

- [1] **Bitwarden**. *Security White Paper*. <https://bitwarden.com/help/bitwarden-security-white-paper/>
- [2] **NIST**. FIPS 197 — Advanced Encryption Standard (AES). National Institute of Standards and Technology.
- [3] **IETF RFC 8018**. PKCS #5: Password-Based Cryptography Specification Version 2.1.
- [4] **Microsoft Azure**. *Transparent Data Encryption (TDE)*. <https://learn.microsoft.com/en-us/azure/azure-sql/database/transparent-data-encryption-tde-overview>
- [5] **W3C**. Web Authentication (WebAuthn) Level 3. World Wide Web Consortium.
- [6] **Bitwarden**. *SSO with Trusted Devices — Key Exchange Documentation*. <https://bitwarden.com/help/trusted-device-encryption/>